

מטרות: הקשחת נתב ב-CLI · אבטחת גישה · SSH · AutoSecure · syslog/NTP/SNMP ·
בבגרות: line vty / login local / secret, מפתחות RSA ל-SSH, פקודת logging

לפני שמתחילים – איך בכלל מדברים עם נתב? (למי שאין רקע)

כל הפרק הזה עוסק ב"הקשחת נתב" – אבל איך פונים לנתב מלכתחילה? הנה הבסיס: CLI (Command Line Interface) – ממשק שורת פקודה. במקום עכבר וחלונות, מקלידים פקודות טקסט. כל ציוד סיסקו מנוהל כך. IOS – מערכת ההפעלה של ציוד סיסקו (כמו Windows למחשב, רק לנתב). ה-CLI הוא הדרך לדבר איתה. **מצבי עבודה** (Modes) – ל-CLI יש "רמות". הסימן שאחרי שם הנתב מראה איפה אתם: R1> – מצב בסיסי (User) – רק צפייה. R1# – מצב מנהל (Privileged) – אחרי הקלדת enable. אפשר הכול. R1(config)# – מצב הגדרות – אחרי configure terminal. כאן משנים הגדרות. R1(config)# – מצב ממשק – מגדירים כרטיס רשת ספציפי. **קונפיגורציה** (Configuration) – כל ההגדרות של הנתב. יש running-config (הפעילה כרגע בזיכרון, נמחקת בכיבוי) ו-startup-config (השמורה, נטענת באתחול). שומרים עם copy running-config startup-config או write. **ממשק** (Interface) – כרטיס רשת/פורט פיזי בנתב, למשל GigabitEthernet0/0 (בקיצור. g0/0). **דוגמה – כניסה והגדרה ראשונה:** Router> enable ! מעבר למצב מנהל Router# configure terminal ! מעבר למצב הגדרות Router(config)# hostname R1 ! שינוי שם הנתב R1# write R1(config)# exit ! שמירת ההגדרות

2.1 למה הנתב הוא המטרה הראשונה

נתב הקצה (Edge router) הוא הנקודה שבה רשת הארגון פוגשת את האינטרנט. מי ששולט בו יכול לנתב תעבורה לאן שירצה, להאזין לה, לחסום אותה או לפתוח פתח פנימה. שלוש גישות לתכנון:

- **נתב יחיד** – הנתב הוא גם חומת האש. (ACL, ZPF) מתאים לעסק קטן. (SOHO).
- **הגנה לעומק** (Defense in depth) – נתב קצה מסנן גם ⇒ חומת אש ייעודית (ASA) ⇒ נתב פנימי. כל שכבה עצמאית.
- **DMZ** – אזור מפורז בין שתי חומות אש (או בין שני ממשקים של אותה חומה) ובו השרתים הציבוריים (web, mail). אם שרת ב-DMZ נפרץ, התוקף עדיין לא בפנים.

אבטחת הנתב עצמו כוללת שלושה תחומים: **אבטחה פיזית** (חדר נעול, UPS – מי שיש לו גישה פיזית לקונסול יכול לאפס סיסמה דרך (password recovery), **אבטחת מערכת ההפעלה** (גרסת IOS עדכנית, זיכרון מספיק, גיבוי של ה-image והקונפיגורציה) **והקשחה** (hardening) – סגירת שירותים מיותרים, סיסמאות, גישה מוצפנת, ניטור. זה ליבת הפרק.

סיפור מהחיים: הנתבים שנשארו עם admin/admin

ב-2016 רשת Mirai הדביקה 600,000 מכשירים – מצלמות אבטחה, ראوترים ביתיים, מקליטי DVR – בשיטה פרימיטיבית להדהים: היא ניסתה 62 צירופים של שם משתמש וסיסמה מברירת המחדל של היצרנים (admin/admin, root/12345, admin/password). זהו. בלי פגיעות מתוחכמות. עם הצבא הזה הופלו ב-DDoS של 1.2 טרה-ביט/שנייה שירות ה-DNS של Dyn, ואיתו Spotify, Netflix, Twitter ו-PayPal. ליום שלם. כל מה שנלמד בפרק הזה – סיסמה חזקה, SSH במקום Telnet, כיבוי שירותים – היה מונע את ההדבקה. שאלו: כמה מכם שינו את הסיסמה של הראوتر בבית?

2.2 שלוש דרכי ניהול לנתב

ממשק	איך מתחברים	אבטחה
Console	כבל קונסול פיזי, line console 0	מי שמגיע פיזית – שולט. חובה סיסמה + exec-timeout.
AUX	פורט עזר למודם (ישן), line aux 0	לרוב מכבים: / no exec transport input none

ממשק	איך מתחברים	אבטחה
(Virtual Terminal) VTY	Telnet/SSH דרך הרשת, line 5 vty 0 4 קווים וירטואליים ב-0; 4-0 IOS חדש 0-15	הנקודה הרגישה ביותר - חייבים SSH בלבד + אימות משתמשים.

In-band מול Out-of-band (OOB)

In-band - ניהול דרך אותה רשת שמעבירה את תעבורת המשתמשים (SSH) מהמשרד לנתב). זול, אבל אם הרשת נופלת - אין ניהול, ואם התוקף ברשת - הוא רואה את תעבורת הניהול.
Out-of-band (OOB) - רשת ניהול נפרדת פיזית או לוגית: שרת קונסולים, VLAN ניהול ייעודי, מודם/LTE לחירום. עדיף לארגונים; לפחות VLAN ניהול נפרד.

2.3 סיסמאות בנתב - מה ההבדל בין כל הסוגים

```
! מדיניות מינימום
R1(config)# security passwords min-length 10
! סיסמת מצב enable - תמיד secret, לעולם לא password
R1(config)# enable secret Str0ng-P@ss
! קונסול
R1(config)# line console 0
R1(config-line)# password C0ns0le-P@ss
R1(config-line)# login
R1(config-line)# exec-timeout 5 0 ! ניתן אחר 5 דק' חוסר פעילות
R1(config-line)# logging synchronous ! שהודעות לוג לא ישברו את השורה שמקלידים
! הצפנת כל הסיסמאות בטקסט גלוי בקונפיג 7 (type) - חלשה, אבל עדיף מכלום
R1(config)# service password-encryption
```

פקודה	איך נשמר בקונפיג	חוזק
enable password X	טקסט גלוי (type 0)	אפס. לא להשתמש.
service password-encryption	re "type 7"èVigen	חלש - מפוענח באתרים אונליין בשנייה. מגן רק מהצצה מעבר לכתף.
enable secret X	MD5 (type 5), ב-0 IOS חדש script (type 9)	גיבוב חד-כיווני - לא ניתן לשחזר. זה מה שמשתמשים בו.
username admin secret X	גיבוב כמו enable secret	חזק - לחשבוניות מקומיים.
username admin password X	גלוי / type 7	חלש - לא להשתמש.

שאלת תלמיד: "אם הגדרתי גם enable password וגם enable secret - מה קובע?"

ה- secret IOS מתעלם מ- enable password כשקיים enable secret (ומזהיר אם הן זהות). למען הסדר - פשוט לא מגדירים enable password.

שאלת תלמיד: "מה ההבדל בין login ל- login local?"

login - מבקש רק את הסיסמה שהוגדרה בקו עצמו (password בתוך line). כולם משתמשים באותה סיסמה, אין שמות, אין מעקב מי נכנס.
login local - מבקש שם משתמש וסיסמה ומאמת מול מסד המשתמשים המקומי (se- ... username ... cret ...). SSH **דורש שם משתמש ולכן חייב** login local (או AAA זה בדיוק מה שנשאל בבגרות שאלה 2א: התשובה הנכונה היא ... login local + username admin privilege 15 secret).

Telnet 2.4 מול SSH – והגדרת SSH צעד אחר צעד

Telnet (TCP 23) מעביר הכול – כולל שם משתמש וסיסמה – בטקסט גלוי. כל מי שמאזין לרשת (Wireshark) רואה אותם. SSH (Secure Shell, TCP 22) מצפין את כל ההפעלה ומאמת את השרת. SSH גרסה 2 בלבד (גרסה 1 פגיעה).

כדי ש-SSH יעבוד, הנתב צריך **זוג מפתחות RSA** (פרק 7 יסביר לעומק: מפתח ציבורי שנשלח ללקוח ומפתח פרטי שנשאר בנתב). כדי לייצר מפתח הנתב צריך שם מלא $\text{hostname} + \text{domain-name} = \text{FQDN}$, כי השם נכנס למפתח.

```
! 1. שם ייחודי ודומיין – חובה לפני יצירת מפתחות
Router(config)# hostname R1
R1(config)# ip domain-name school.local
! 2. יצירת זוג מפתחות RSA (2048 ביט ומעלה)
R1(config)# crypto key generate rsa general-keys modulus 2048
The name for the keys will be: R1.school.local
! 3. משתמש מקומי
R1(config)# username admin privilege 15 secret Admin-P@ss
! 4. פרמטרים של SSH
R1(config)# ip ssh version 2
R1(config)# ip ssh time-out 60 ! זמן לסיום ההזדהות
R1(config)# ip ssh authentication-retries 2
! 5. קווי VTY – רק SSH, אימות מקומי
R1(config)# line vty 0 4
R1(config-line)# login local
R1(config-line)# transport input ssh ! חוסם Telnet לחלוטין
R1(config-line)# exec-timeout 5 0
! בדיקה
R1# show ip ssh
R1# show ssh ! חיבורים פעילים
R1# show crypto key mypubkey rsa
! חיבור מנתב אחר / ממחשב
R2# ssh -l admin 10.0.0.1
PC> ssh -l admin 10.0.0.1
```

טעויות נפוצות בהגדרת SSH

- שכחו `ip domain-name` ⇒ הפקודה `crypto key generate rsa` נכשלת ("Please define a domain-name first").
- השאירו `hostname "Router"` ⇒ אותה שגיאה.
- הגדירו `login` במקום `login local` ⇒ SSH דוחה ("Password required, but none set") / אין אימות בשם משתמש).
- מפתח קטן מ-768 ביט לא מאפשר SSHv2. משתמשים ב-1024 לפחות; מומלץ 2048.
- `transport input ssh` חוסם Telnet – אם התלמיד היה מחובר ב-Telnet הוא לא יינתק, אבל חיבור הבא ייכשל. זה מכוון.

בבגרות (שאלה ב5)

"מנהל רשת הפיק מפתחות RSA בנתב. מה ניתן לעשות כעת עם המפתחות?" – ניתן להשתמש בהם לצורך חיבור SSH (ללא צורך באיפוס). Telnet לא משתמש במפתחות כלל.

סיפור מהחיים: Telnet בבית חולים

בבדיקת חדירה בבית חולים (סיפור שמופיע בדוחות של חברות אבטחה רבות), הבודקים חיברו מחשב נייד לשקע רשת בחדר המתנה, הריצו Wireshark, וחיכו. תוך 40 דקות הם לכדו session של Telnet של טכנאי שהתחבר למתג הראשי – שם משתמש וסיסמה בטקסט גלוי. עם הסיסמה הזו הם קיבלו שליטה בכל המתגים

בבניין. הטכנאי לא עשה שום דבר "לא נכון" - הוא פשוט השתמש בכלי שהיה זמין. ההגנה: transport ssh - שורה אחת.

2.5 רמות הרשאה (Privilege Levels) ותצוגות תפקיד (Role-Based CLI Views)

ל-IOS יש 16 רמות הרשאה (0-15). ב-15 פועל משתמש בשלוש:

מה מותר	שם	רמה
disable, enable, exit, help, login, logout	-	0
פקודות show בסיסיות, ping, ברירת מחדל אחרי login.	(R1>) User EXEC	1
מה שהמנהל מעביר אליהן בעזרת privilege	מותאם אישית	14-2
הכול, כולל configure terminal	(R1#) Privileged EXEC	15

```

! רמה 5: מותר גם reload ו-show running-config
R1(config)# privilege exec level 5 reload
R1(config)# privilege exec level 5 show running-config
R1(config)# enable secret level 5 Lvl5-P@ss
R1(config)# username helpdesk privilege 5 secret Help-P@ss
! כניסה לרמה
R1> enable 5
R1# show privilege
Current privilege level is 5

```

מגבלות של רמות: אין שליטה "בין רמות" (רמה 5 מקבלת אוטומטית גם כל מה שמותר ב-1-4), ופקודות show מסוימות חושפות הרבה. הפתרון המדויק יותר: Role-Based CLI Views - "תצוגה" שמכילה רשימת פקודות מדויקת. דורש AAA מופעל.

```

R1(config)# aaa new-model
R1(config)# exit
! נכנסים ל-root view (מבקש enable secret)
R1# configure terminal
R1(config)# parser view MONITOR
R1(config-view)# secret Mon-P@ss
R1(config-view)# commands exec include show ip interface brief
R1(config-view)# commands exec include show ip route
R1(config-view)# commands exec include ping
R1(config-view)# exit
! משתמש שמשויך לתצוגה
R1(config)# username noc view MONITOR secret Noc-P@ss
! בדיקה
R1# enable view MONITOR
R1# show parser view
Current view is 'MONITOR'

```

Superview - תצוגה שמאגדת כמה תצוגות (view MONITOR => parser view ADMIN superview).

2.6 Banner - אזהרה משפטית

```

R1(config)# banner motd #
** UNAUTHORIZED ACCESS IS PROHIBITED ***
This system is for authorized personnel only.

```

```
All activity is monitored and logged.
```

```
#
```

טיפ: מה לא לכתוב בבאנר

לא "Welcome" (בית משפט בארה"ב קיבל טענה של פורץ ש"הוזמן"), לא שם החברה, לא דגם הנתב, לא שם המנהל. רק אזהרה ותו לא. ה-motd מוצג לפני ההזדהות; login banner מוצג אחרי motd ולפני בקשת שם משתמש; exec banner אחרי הכניסה.

Syslog-2.7 Logging

הנתב מייצר הודעות על אירועים (ממשק עלה/ירד, כניסה כושלת, ACL שחסם). ניתן לשלוח אותן ל: **קונסול** (ברירת מחדל), **קווי VTY** (terminal monitor), **חוצץ בזיכרון** (buffer) - נמחק ב-(reload, **ושרת** syslog (UDP 514) - היעד הנכון לארגון, כי הלוגים נשמרים גם אם הנתב נפרץ או אופס.

מבנה הודעה

```
*Mar 1 00:12:45.123: %LINK-3-UPDOWN: Interface FastEthernet0/1, changed state to down
^מז^ ^severity ^mnemonic ^ואית
```

8 רמות חומרה (Severity) - חובה לזכור

רמה	שם	משמעות
0	Emergencies	המערכת אינה שמישה
1	Alerts	נדרשת פעולה מיידי
2	Critical	מצב קריטי
3	Errors	שגיאה (ממשק נפל)
4	Warnings	אזהרה
5	Notifications	אירוע רגיל אך משמעותי (ממשק עלה, config שונה)
6	Informational	מידע (ACL match)
7	Debugging	פלט debug - עצום, רק לפתרון תקלות

מנמוניקה באנגלית: **Every Awesome Cisco Engineer Will Need A Little Help** (רמה 0 = 4-4).

```
R1(config)# logging host 2.9.20.22 (זו התשובה בבגרות שאלה 2) ! או בקיצור: logging 2.9.20.22
R1(config)# logging trap warnings 4) (אפשר לכתוב 4-0) ! שלח לשרת רמות 0-4
R1(config)# logging source-interface loopback 0
R1(config)# logging buffered 16384 informational 6-0 רמות, 16KB חוצץ !
R1(config)# service timestamps log datetime msec ! חותמת זמן - חסר טעם בלי NTP !
R1(config)# logging on
R1# show logging
```

NTP 2.8 - למה זמן מדויק הוא עניין של אבטחה

לוגים בלי זמן נכון חסרי ערך: אי אפשר לשחזר סדר אירועים בין נתב, חומת אש ושרת. גם תעודות דיגיטליות (פרק 7) ומפתחות IPsec (פרק 8) תלויים בזמן. NTP (Network Time Protocol, UDP 123) מסנכרן את כל הציוד למקור אחד. Stratum - מרחק ממקור הזמן (stratum 0 = שעון אטומי/1, stratum GPS = שרת שמחובר אליו ישירות...).

```

NTP נתב כלקוח !
R1(config)# ntp server 10.0.0.5
R1(config)# clock timezone IST 2
! אימות NTP - שלא יזייפו לנו את הזמן
R1(config)# ntp authenticate
R1(config)# ntp authentication-key 1 md5 NtpK3y
R1(config)# ntp trusted-key 1
R1(config)# ntp server 10.0.0.5 key 1
! נתב כשרת NTP לרשת הפנימית
R1(config)# ntp master 3
R1# show ntp status
R1# show ntp associations
R1# show clock

```

SNMP 2.9 - ניטור ציוד, ולמה גרסה 3

SNMP (Simple Network Management Protocol, UDP 161/162) מאפשר לתחנת ניהול (NMS) - PRTG, SolarWinds, Zabbix לקרוא נתונים מהנתב (GET) - תעבורה, CPU ואף לשנות (SET). הנתב יכול גם לשלוח התראות יזומות (trap). הנתונים מאורגנים ב-MIB (עץ של משתנים, כל אחד עם מזהה OID).

גרסה	אימות	הצפנה	הערכה
SNMPv1	Community string בטקסט גלוי public"/"private")")	אין	לא לשימוש
SNMPv2c	Community string בטקסט גלוי	אין	נפוץ, אך חלש - לפחות read-only + ACL
SNMPv3	HMAC + משתמש (MD5/SHA)	DES/AES	היחיד המומלץ . noAuthNoPriv, authNoPriv, authPriv

```

! v2c מוגבל (אם חייבים): קריאה בלבד ורק מ-NMS
R1(config)# access-list 5 permit host 10.0.0.50
R1(config)# snmp-server community S3cr3tR0 ro 5
! v3 - הדרך הנכונה
R1(config)# snmp-server group ADMINS v3 priv
R1(config)# snmp-server user monitor ADMINS v3 auth sha AuthP@ss priv aes 128 PrivP@ss
R1(config)# snmp-server host 10.0.0.50 version 3 priv monitor
R1(config)# snmp-server enable traps
R1# show snmp

```

2.10 שירותים שסוגרים ו-AutoSecure

ה-IOS מגיע עם שירותים שהיו נחוצים פעם והיום הם רק שטח תקיפה. רשימת הקשחה ידנית:

```

R1(config)# no cdp run ! CDP חושף דגם, IOS וכתובות לשכנים (השאירו על קישורים פנימיים אם צריך)
R1(config)# no ip http server ! ממשק web - או ip http secure-server אם חייבים
R1(config)# no ip finger
R1(config)# no ip bootp server
R1(config)# no service tcp-small-servers
R1(config)# no service udp-small-servers
R1(config)# no ip source-route ! מונע מהשולח להכתיב מסלול
R1(config)# no service pad

```

```
R1(config)# interface g0/0
R1(config-if)# no ip redirects
R1(config-if)# no ip proxy-arp
R1(config-if)# no ip unreachable
R1(config-if)# no ip directed-broadcast (נגד Smurf ברירת מחדל כבר כך)
```

AutoSecure – פקודה אחת שעושה את רוב זה: מכבה שירותים מסוכנים, מפעילה שירותי אבטחה (logging, login block), מקשיחה ממשקים, ומציעה להגדיר SSH ו-CBAC במצב אינטראקטיבי שואלת שאלות; במצב no-interact משתמשת ברירות מחדל.

```
R1# auto secure
R1# auto secure no-interact
R1# show auto secure config
```

שאלת תלמיד: "אז למה לא פשוט להריץ auto secure תמיד?"

כי הוא "עיוור": יכול לכבות CDP שהמתגים צריכים, להפעיל חומת אש (CBAC) שתחסום תעבורה לגיטימית, ואי אפשר לבטל אותו בפקודה אחת (no auto secure לא קיים – צריך לשחזר config). מומלץ להריץ אותו, לבדוק את מה שהוא שינה עם show auto secure config, ולכוון.

2.11 שמירה על ה-IOS והקונפיג – Resilient Configuration

תוקף שהשיג גישה יכול למחוק את ה-IOS ואת ה-startup-config ולהשבית את הנתב. תכונת IOS Resilient Configuration שומרת עותק מוגן (bootset) שלא ניתן למחוק מה-CLI, גם לא ב-format flash.

```
R1(config)# secure boot-image
R1(config)# secure boot-config
R1# show secure bootset
R1(config)# secure boot-config restore flash:rescue-cfg ואז ROMMON > boot flash:<image> שחזור!
```

גיבוי שוטף: tftp running-config archive / copy + path + time-period לגיבוי אוטומטי.

2.12 ביקורת חשבונות (Auditing)

לדעת מי עשה מה ומתי. הכלים בפרק זה: login on-success log / login on-failure log, archive log config (רישום כל פקודת config עם שם המשתמש), syslog מרכזי, ו-show users לראות מי מחובר עכשיו. הרחבה מלאה – Accounting של AAA בפרק 3.

```
R1(config)# archive
R1(config-archive)# log config
R1(config-archive-log-cfg)# logging enable
R1(config-archive-log-cfg)# hidekeys ! לא לרשום סיסמאות
R1# show archive log config all
```

2.13 SDM / CCP – מה זה ומה אומרים לתלמידים

תכנית הלימודים מזכירה "SDM לוריפיקציה". SDM (Security Device Manager) היה ממשק גרפי מבוסס Java שרץ בדפדפן מול הנתב והציע אשפים (wizards) ל-SSH, חומת אש, VPN ו-"Security Audit" – סריקה שמציגה רשימת שירותים מסוכנים ומציעה לתקן בלחיצה ("One-step lockdown", המקבילה הגרפית של Au-toSecure). SDM הוחלף ב-CCP (Cisco Configuration Professional) ב-2009, ו-CCP הופסק ב-2015. **הבגרות בודקת CLI בלבד.** אמרו לתלמידים: "קיימים ממשקים גרפיים; אנחנו לומדים CLI כי הוא אוניברסלי, מדויק ונשאל בבחינה".

2.14 מדריך פקודות מרוכז – פרק 2

פקודה	מצב	תפקיד
enable secret X	config	סיסמת enable מגובבת
service password-encryption	config	מסתיר סיסמאות type 7
security passwords min-length N	config	אורך סיסמה מינימלי
username U privilege 15 secret P	config	משתמש מקומי
login block-for S attempts N within T	config	הגנה מ-brute force
/ip domain-name D crypto key generate rsa	config	הכנה ל-SSH
ip ssh version 2	config	SSHv2 בלבד
login → line vty 0 4 transport input local ssh	line	גישה מרחוק מאובטחת
exec-timeout M S	line	ניתוק חוסר פעילות
privilege exec level N CMD	config	העברת פקודה לרמה
parser view V	aaa config (אחרי new-model)	תצוגת תפקיד
banner motd #...#	config	אזהרה
/logging host IP logging trap LEVEL	config	syslog
ntp/ntp server IP authenticate	config	זמן
snmp-server ...	config	ניטור
auto secure	exec	הקשחה אוטומטית
/secure boot-image secure boot-config	config	הגנה על IOS וקונפיג
show,show ip ssh show ntp,logging ,show privilege,status show login	exec	ורטיפיקציה

2.15 תרגילים לתלמידים

תרגיל 1 - מצאו את 5 הבעיות בקונפיג

```
Router(config)# enable password cisco Router(config)# line vty 0 4 Router(config-line)#
password cisco Router(config-line)# login Router(config-line)# transport input telnet
Router(config)# # !Router(config)# banner motd # Welcome to ACME Corp main router
snmp-server community public rw
```

1. enable password במקום enable secret (טקסט גלוי). 2. hostname. 3. SSH. סיסמה חלשה "cisco" ובלי שם משתמש (login במקום login). 4. transport input telnet - לא מוצפן; צריך. 5. ssh. באנר "Welcome" עם שם (local). 6. SNMP community "public" עם הרשאת rw - כל אחד יכול לשנות את הקונפיג. 7. אין exec-timeout. (כל 5 מתוך 7 מתקבלים).

תרגיל 2 - סדר נכון

סדרו את הפקודות הבאות בסדר שבו חייבים להקליד אותן כדי ש-SSH יעבוד: crypto key generate username · hostname R1 · transport input ssh · ip domain-name lab.local · rsa

```
line vty 0 4 · login local · admin secret P@ss
```

username admin → crypto key generate rsa → ip domain-name lab.local → hostname R1
transport input ssh. (username → login local → line vty 0 4 → secret P@ss
crypto key.) מקום לפני domain-name ו-login local; hostname לפני

תרגיל 3 – syslog

הנתב הגדיר 4 logging trap. סמנו אילו מההודעות יגיעו לשרת:
א. %SEC_LOGIN-3-UPDOWN. ב. %SYS-5-CONFIG_I: Configured from console. ג. %SEC_LOGIN-3-UPDOWN. ד. %SEC-6-IPACCESSLOGP. ה. %OSPF-5-ADJCHG. ו. %SEC-6-IPACCESSLOGP.
ב (3) ו-ג (4) יגיעו. א (5), ד (6), ה (5) לא – חמורים פחות מ-4. **מנומניקה:** המספר במרכז ההודעה הוא רמת החומרה.

תרגיל 4 – תכנון

אתם מנהלי הרשת של בית ספר עם 3 נתבים ו-12 מתגים. כתבו רשימת 8 צעדי הקשחה שתבצעו על כל מכשיר, לפי סדר עדיפות, ונמקו את הראשון.
דוגמה: enable secret + username secret (בלי זה – כל השאר חסר ערך). 2. SSH. 3. login block-for. 4. exec-timeout. 5. syslog + NTP config. 6. small servers. 7. SNMPv3. 8. banner. 9. secure boot-image/config. 10. HTTP, CDP כיבוי מרכזי. 11. Telnet לשרת מרכזי. 12. SSH. 13. login block-for. 14. exec-timeout. 15. syslog + NTP config. 16. small servers. 17. SNMPv3. 18. banner. 19. secure boot-image/config. 20. HTTP, CDP כיבוי מרכזי.

2.16 שאלות בסגנון בגרות

שאלה 1

מנהל רשת הקליד: R1, hostname R1, crypto key generate rsa – וקיבל שגיאה. מה חסר?
ip domain-name. יצירת מפתחות RSA דורשת. FQDN (hostname + domain).

שאלה 2

מהו הסדר הנכון של רמות חומרה ב-syslog מהחמורה לקלה: Warning, Emergency, Debugging, Error?
Debugging (7). → Warning (4) → Error (3) → Emergency (0)

שאלה 3

השלימו כדי לאפשר גישה מרחוק ב-Ssh בלבד עם אימות מול משתמש מקומי:
R1(config)# line vty 0 4
R1(config-line)# _____
R1(config-line)# _____
login local ו-transport input ssh.

שאלה 4

מנהל הגדיר 3 logging trap. אילו הודעות יישלחו לשרת ה-syslog?
רמות 0-3: Emergencies, Alerts, Critical, Errors. הודעות Warning ומטה לא יישלחו.

שאלה 5

נכון / לא נכון: (א) service password-encryption מצפין את הסיסמאות באופן שאינו ניתן לפענוח.
(ב) SNMPv3 תומך בהצפנה. (ג) NTP משתמש ב-TCP (ד) SSH גרסה 1 מאובטחת יותר מגרסה 2.

(א) לא נכון - type 7, ניתן לפענוח בקלות. (ב) נכון. (ג) לא נכון. - UDP 123 (ד) לא נכון.

שאלה 6

איזו פקודה תגרום לנתב לנתק משתמש בקונסול לאחר 3 דקות ללא פעילות?

0 line console → 0 3 exec-timeout.

2.17 מעבדה (2 שעות) - הקשחת נתב ב-Packet Tracer

1. טופולוגיה: PC — Switch — R1 — Server-PT Syslog/NTP server עם שירותי SYSLOG ו-NTP מופעלים).
2. הגדירו. hostname, enable secret, min-length, service password-encryption, banner.
3. הגדירו SSH לפי 2.4. נסו Telnet - ודאו שנכשל. התחברו ב-SSH מה-PC.
4. הפעילו 30 within 3 login block-for 60 attempts; נסו 3 סיסמאות שגויות; ראו ב-show login את מצב ה-quiet mode.
5. הגדירו logging לשרת ו-logging trap informational; כבו והדליקו ממשק; ראו את ההודעה בשרת ה-Syslog.
6. הגדירו NTP מול השרת; ודאו ב-show ntp status ש-synchronized.
7. צרו משתמש ברמה 5 שיכול רק show running-config; בדקו שאינו יכול להיכנס ל--configure terminal.

עוד דוגמאות מהעולם האמיתי

(2018) VPNFilter - חצי מיליון נתבים ביתיים נחטפו

נוזקה בשם VPNFilter הדביקה מעל 500,000 נתבים ביתיים וקטנים בעולם (Linksys, MikroTik, Net-gear, TP-Link ועוד). היכולות שלה: ריגול אחר כל התעבורה שעוברת בנתב, גניבת סיסמאות, ואף "הריגת" הנתב (bricking) בפקודה אחת. ה-FBI ייחס אותה לתקיפה מדינתית והשתלט על שרת השליטה (C2) שלה כדי לעצור אותה. **איך היא נכנסה?** חולשות ידועות שלא עודכנו + סיסמאות ברירת מחדל שלא שוננו. לקח: נתב ביתי הוא מחשב מלא - בלי הקשחה ועדכון הוא הדלת הקלה ביותר פנימה.

הדגל האמריקאי על 168,000 נתבים (Cisco Smart Install, 2018)

קבוצת האקרים ניצלה שירות ניהול של סיסקו בשם Smart Install (פורט 4786 TCP) שנשאר טנרטינאל פושח חותך בעשרות אלפי ארגונים. הם מצאו את המכשירים החשופים דרך מנוע החיפוש Shodan, איפסו את הקונפיגורציה של כ-168,000 נתבים, ובחלקם כתבו קונפיג עם דגל אמריקאי ב-ASCII והודעה "Don't mess with our elections". נפגעו ספקיות אינטרנט באיראן וברוסיה. **לקח:** שירות ניהול מיותר שנשאר פתוח = הזמנה. זו בדיוק הסיבה שמכבים כל שירות שלא נחוץ (no ...) ומריצים AutoSecure.

Shodan - "גוגל של המכשירים המחוברים"

Shodan הוא מנוע חיפוש שסורק כל הזמן את האינטרנט ומקטלג מכשירים חשופים: נתבים, מתגים, מצלמות אבטחה, ואפילו בקרים תעשייתיים. אפשר לחפש בו מכשירים עם "public" SNMP, עם Telnet פתוח, או עם סיסמת ברירת מחדל - ולקבל רשימה של אלפים. תוקפים משתמשים בו לשלב הסיור (פרק 1); אנשי אבטחה משתמשים בו כדי לגלות מה ההלש נוגראה חושף בטעות. כל פעולה שעשינו בפרק הזה - SSH במקום Telnet, SNMPv3, כיבוי שירותים - מורידה אתכם מהרשימה של Shodan.

תרגיל 5 - קישור סיפור להקשחה

לכל סיפור מהעולם האמיתי לעיל, איזו פקודת/פעולת הקשחה מהפרק הייתה מונעת אותו?

VPNFilter: שינוי סיסמת ברירת מחדל (enable secret, username secret) + עדכון IOS.

Smart Install: כיבוי השירות המיותר (no vstack / כיבוי שירותים + SSH: Shodan: AutoSecure).
במקום Telnet, SNMPv3, וכיבוי כל שירות פתוח מיותר.

תרגיל 6 – תכנון הקשחה

אתם מנהלי הרשת של בית ספר עם 3 נתבים. כתבו 6 צעדי הקשחה שתבצעו על כל נתב, לפי סדר עדיפות, ונמקו את הראשון.

דוגמה: 1. enable secret + username ... secret (בלי זה כל השאר חסר ערך – אין הגנה בסיסית). 2. SSH בלבד (login local + transport input ssh), כיבוי 3. login Telnet. 4. block-for נגד ניחוש סיסמאות. 5. NTP + syslog. 6. banner. 7. SNMPv3. 8. HTTP/CDP כיבוי הקונפיג.

בנק שאלות שתלמידים שואלים – ותשובות מוכנות

שאלות נפוצות בפרק הקשחת הנתב, עם תשובות מוכנות.

סיסמאות וגישה

ש: "אם אני שם סיסמה חזקה ל-Telnet, למה בכל זאת צריך SSH?"
ת: כי Telnet מעביר את לוכה בטקסט גלוי, כולל את הסיסמה החזקה עצמה. כל מי שמאזין לרשת (Wireshark) רואה אותה. SSH מצפין את כל התקשורת. חוזק הסיסמה לא עוזר אם היא נשלחת גלויה.

ש: "מה ההבדל בין password ל-secret?"
ת: secret נשמר כינוויכ-דח בוביג (לא ניתן לשחזר). password נשמר גלוי, ואפילו עם service password-encryption הוא רק "type 7" שמפוענח באתר אונליין בשנייה. תמיד להשתמש ב-secret.

ש: "אם service password-encryption, למה היא חלשה?"
ת: כי זה אלגוריתם הפיך וישן (וריאציה על Vigen). re) הוא מגן רק מפני מישהו שמציץ מעבר לכתף בזמן שאתם צופים בקונפיג – לא מפני תוקף אמיתי. ה"חוזק" האמיתי הוא ב-secret (גיבוב).

ש: "מה קורה אם שכחתי את ה-enable secret?"
ת: יש הליך password recovery דרך גישה פיזית לקונסול: מאתחלים, נכנסים ל-ROMMON, משנים את ה-configuration register (0x2142) כדי לדלג על ה-startup-config, ומגדירים סיסמה חדשה. המסקנה החשובה: וב טלוש – בתנל תיזיפ השיג ול שיש ימ, ולכן אבטחה פיזית קריטית.

ש: "מה ההבדל בין רמות הרשאה (privilege levels) לתצוגות (views)?"
ת: רמות הרשאה גסות – רמה נתונה מקבלת אוטומטית גם את כל מה שמתחתיה. תצוגות (parser view) מדויקות – מגדירים רשימת פקודות מדויקת לכל תפקיד, אך דורשות שה-AAA יופעל.

SSH

ש: "למה צריך ip domain-name כדי ליצור מפתחות SSH?"
ת: כי שם המפתח נגזר מהשם המלא של הנתב = hostname + domain-name (FQDN). לא יודע איזה שם לתת למפתח, והפקודה נכשלת עם "Please define a domain-name first".

ש: "אחרי transport input ssh ניתקתי בטעות את Telnet – זו טעות?"
ת: לא, זה בדיוק מה שרוצים – לחסום את Telnet הלא-מאובטח ולאפשר רק SSH. חיבור Telnet חדש ייכשל, וזו התנהגות רצויה.

שירותים וניטור

ש: "למה זמן מדויק (NTP) קשור לאבטחה בכלל?"
ת: כי בלי זמן מסונכרן, הלוגים מכל המכשירים לא ניתנים לשחזור – אי אפשר לדעת מה קרה לפני מה כשחוקרים אירוע. בנוסף, תעודות דיגיטליות ומפתחות VPN תלויים בזמן נכון.

ש: "SNMPv2 באמת כל כך גרוע?"
ת: הבעיה שלו היא ה-community string (ולעיתים נשאר "public"). אם חייבים v2c – לפחות read-only + הגבלה ב-ACL לכתובת תחנת הניהול. אבל הנכון הוא v3, שמוסיף אימות (HMAC) והצפנה.

ש: "אז למה שלא נריץ תמיד auto secure ונגמור עם זה?"

ת: כי הוא "עיוור" - יכול לכבות CDP שהמתגים צריכים, להפעיל חומת אש שתחסום תעבורה לגיטימית, ואי אפשר לבטלו בפקודה אחת. מריצים אותו, בודקים מה שינה עם `show auto secure config`, ומכוונים.

ש: "מה זה בעצם CLI, ולמה לא ללמוד ממשק גרפי?"

ת: CLI הוא ממשק שורת הפקודה של הנתב. אנחנו לומדים אותו כי הוא אוניברסלי (עובד על כל ציוד סיסקו וגם דרך SSH, מדויק, וניתן לאוטומציה - דבלב ותוא תקדוב תורגבהו. הממשקים הגרפיים (SDM/CCP) יצאו משימוש.

מילון מונחים - הגדרות

הגדרות תמציתיות של המונחים המרכזיים בפרק. שימושי גם כדף עזר לבחינה (מותר מילון מונחים).

מונח	הגדרה
CLI (Command Line Interface)	ממשק שורת פקודה לניהול ציוד רשת בהקלדת פקודות טקסט.
IOS	מערכת ההפעלה של ציוד סיסקו.
running-config	ההגדרות הפעילות בזיכרון; נחקות בכיבוי אם לא נשמרו.
startup-config	ההגדרות השמורות שנטענות באתחול הנתב.
Console / VTY / AUX	דרכי גישה לנתב: קונסול (פיזי), VTY (מרחוק ברשת), AUX (מודם ישן).
In-band / OOB	ניהול דרך רשת הנתונים (In-band) או דרך רשת ניהול נפרדת (Out-of-band).
enable secret	סיסמת מצב מנהל, נשמרת כגיבוב חד-כיווני (בטוח).
service password-encryption	מסתיר סיסמאות בקונפיג בהצפנה חלשה (type 7) - מגן רק מהצצה.
SSH (Secure Shell)	פרוטוקול ניהול מרחוק מוצפן (פורט 22); מחליף את Telnet הלא-מאובטח.
Telnet	פרוטוקול ניהול מרחוק לא מוצפן (פורט 23) - מסוכן, לא לשימוש.
מפתחות RSA	זוג מפתחות (ציבורי/פרטי) שהנתב מייצר כדי לאפשר הצפנת SSH.
רמות הרשאה (Privilege levels)	16 רמות (0)-(15) הקובעות אילו פקודות מותרות; 15 = הכול.
Parser View	תצוגת תפקיד - רשימת פקודות מדויקת למשתמש; דורשת AAA.
Banner	הודעת אזהרה משפטית המוצגת בכניסה לנתב.
Syslog	מנגנון יומן אירועים; שולח הודעות לשרת מרכזי (UDP 514).
Severity levels	8 רמות חומרה ליומן (0=Emergency עד 7=Debug).
NTP (Network Time Protocol)	מסנכרן שעונים בכל הציוד (UDP 123); קריטי ללוגים ולתעודות.
SNMP	פרוטוקול לניטור ציוד (UDP 161); גרסה 3 בלבד מאובטחת.
AutoSecure	פקודה שמבצעת הקשחה אוטומטית של הנתב בצעד אחד.
Hardening (הקשחה)	סגירת שירותים מיותרים והגדרות אבטחה למזעור שטח התקיפה.
err-disabled	מצב שבו פורט מושבת אוטומטית עקב הפרת אבטחה.